

Encryption Standards V1.6

Organization: Company A - Saudi Healthcare Authority
Document ID: SEC-STD-005
Version: 1.6
Classification: CONFIDENTIAL
Date: May 18, 2024
Total Pages: 24
Status: APPROVED

DOCUMENT CONTROL

Version	Date	Author	Changes	Approver
1.0	February 10, 2021	Omar Al-Rashid	Initial encryption standards	Mohammed Al-Zahrani
1.2	August 22, 2022	Omar Al-Rashid	Added TLS 1.3 requirements	Security Board
1.4	March 15, 2023	Saleh Al-Dosari	Enhanced key management procedures	Omar Al-Rashid
1.5	November 8, 2023	Saleh Al-Dosari	HSM integration standards	Security Board
1.6	May 18, 2024	Saleh Al-Dosari	Post-quantum cryptography readiness	Security Board

Document Owner: Security Architecture Board
Review Cycle: Annual (Next Review: May 2025)
Distribution: IT Security, System Administrators, Database Administrators, Application Teams

APPROVAL SIGNATURES

Role	Name	Signature	Date
Information Security Officer	Omar Al-Rashid	[Signed]	May 18, 2024
IT Operations Director	Mohammed Al-Zahrani	[Signed]	May 17, 2024
Chief Data Officer	Dr. Khalid Al-Otaibi	[Signed]	May 16, 2024
Enterprise Architect	Faisal Al-Harbi	[Signed]	May 15, 2024

TABLE OF CONTENTS

1. INTRODUCTION	4
2. ALGORITHM STANDARDS	6
3. DATA AT REST ENCRYPTION	9
4. DATA IN TRANSIT ENCRYPTION	13
5. KEY MANAGEMENT SYSTEM (KMS)	17
6. CERTIFICATE MANAGEMENT	21
7. COMPLIANCE AND MONITORING	23
APPENDIX A: CIPHER SUITE CONFIGURATION	24
APPENDIX B: KEY CEREMONY PROCEDURES	25

1. INTRODUCTION

1.1 Purpose

This document establishes mandatory encryption standards for Company A to protect the confidentiality, integrity, and authenticity of organizational data. These standards ensure that even if physical or logical controls fail (e.g., stolen device, network interception, database breach), the data remains cryptographically protected and unreadable to unauthorized parties.

1.2 Scope

These standards apply to:

- All data classified as INTERNAL, CONFIDENTIAL, or SECRET
- All systems processing, storing, or transmitting sensitive data
- All endpoints (laptops, workstations, mobile devices)
- All network communications
- All databases and file storage systems
- All cloud services and external integrations

1.3 Regulatory Requirements

Regulation	Requirement	Implementation
NDMO Domain 5	Data security controls	This standard
PDPL Article 17	Technical safeguards for personal data	Encryption requirements
SAMA CSF	Financial data encryption	Banking system encryption
CBAHI	Healthcare data protection	PHI encryption
ISO 27001 A.10	Cryptographic controls	Full implementation

1.4 Definitions

Term	Definition
DEK	Data Encryption Key - encrypts actual data
KEK	Key Encryption Key - encrypts DEKs
HSM	Hardware Security Module - tamper-resistant key st
TDE	Transparent Data Encryption - database-level encry
FDE	Full Disk Encryption - volume-level encryption
PFS	Perfect Forward Secrecy - unique session keys

2. ALGORITHM STANDARDS

2.1 Approved Algorithms (Green List)

2.1.1 Symmetric Encryption

Algorithm	Key Size	Mode	Use Case	Status
AES-256	256-bit	GCM	General encryption (preferred)	APPROVED
AES-256	256-bit	CBC	Legacy compatibility	APPROVED
AES-128	128-bit	GCM	Performance-sensitive	APPROVED (limited)
ChaCha20-Poly1305	256-bit	AEAD	Mobile/IoT devices	APPROVED

Note: GCM (Galois/Counter Mode) is preferred as it provides both encryption and authentication (AEAD).

2.1.2 Asymmetric Encryption

Algorithm	Key Size	Use Case	Status
RSA	3072-bit	Key exchange, signatures	APPROVED
RSA	4096-bit	Long-term keys, CA	APPROVED (preferred)
ECDSA	P-384 (secp384r1)	Digital signatures	APPROVED
ECDH	P-384 (secp384r1)	Key exchange	APPROVED
Ed25519	256-bit	Digital signatures	APPROVED

X25519	256-bit	Key exchange	APPROVED
--------	---------	--------------	----------

2.1.3 Hash Functions

Algorithm	Output Size	Use Case	Status
SHA-256	256-bit	General hashing	APPROVED
SHA-384	384-bit	High-security applications	APPROVED
SHA-512	512-bit	High-security applications	APPROVED
SHA-3-256	256-bit	Post-quantum readiness	APPROVED
BLAKE2b	Variable	High-performance hashing	APPROVED

2.1.4 Key Derivation Functions

Algorithm	Use Case	Status
PBKDF2-HMAC-SHA256	Password hashing (100,000+ iterations)	APPROVED
Argon2id	Password hashing (preferred)	APPROVED
HKDF-SHA256	Key derivation from shared secrets	APPROVED
scrypt	Password hashing (memory-hard)	APPROVED

2.2 Prohibited Algorithms (Red List)

2.2.1 Banned - Critical Vulnerabilities

Algorithm	Reason	Remediation Deadline
DES	56-bit key - trivially broken	Immediate
3DES	Performance, 112-bit effective security	December 2024
RC4	Multiple attacks (NOMORE, Bar-mitzvah)	Immediate
MD5	Collision attacks, broken	Immediate
SHA-1	Collision attacks (SHAttered)	Immediate
RSA < 2048-bit	Insufficient key size	Immediate
ECDSA < P-256	Insufficient security	Immediate

2.2.2 Deprecated - Phase Out Required

Algorithm	Reason	Phase-Out Date
TLS 1.0	Known vulnerabilities	Already prohibited
TLS 1.1	Known vulnerabilities	Already prohibited
RSA 2048-bit	Transition to 3072+	December 2025
AES-128 (non-healthcare)	Upgrade to AES-256	December 2025

2.3 Post-Quantum Cryptography Readiness

In preparation for quantum computing threats, Company A is evaluating:

Algorithm	Type	Standard	Status
CRYSTALS-Kyber	Key encapsulation	NIST PQC	Pilot evaluation
CRYSTALS-Dilithium	Digital signature	NIST PQC	Pilot evaluation
SPHINCS+	Digital signature	NIST PQC	Under review

Timeline: Hybrid classical/PQC implementations by 2027

3. DATA AT REST ENCRYPTION

3.1 Database Encryption

3.1.1 Oracle Database (Epic EHR, Oracle EBS)

Component	Method	Key Storage	Status
Tablespaces	TDE (AES-256)	Oracle Wallet / OKV	Enabled
Backups	RMAN encryption	Oracle Wallet	Enabled
Data Pump exports	Encryption parameter	Oracle Wallet	Required
Redo logs	TDE	Oracle Wallet	Enabled

Configuration:

```
sql
```

```
-- Verify TDE status
```

```
SELECT tablespace_name, encrypted FROM dba_tablespaces;
```

```
-- All healthcare tablespaces must show ENCRYPTED = YES
```

3.1.2 SQL Server Databases

Component	Method	Key Storage	Status
Databases	TDE (AES-256)	SQL Server EKM	Enabled
Backups	Backup encryption	Certificate-based	Required
Always Encrypted	Column-level	Azure Key Vault	PII columns

3.1.3 PostgreSQL Databases

Component	Method	Key Storage	Status
Data files	pgcrypto + storage encryption	HSM	Enabled
Connections	SSL required	Certificate	Enforced

3.2 File Storage Encryption

3.2.1 Network Attached Storage (NetApp)

Feature	Configuration	Status
Volume Encryption	NVE (AES-256)	Enabled
Aggregate Encryption	NAE	Enabled
Key Management	External (KMIP to HSM)	Configured

3.2.2 Cloud Storage (AWS S3)

Bucket Type	Encryption Method	Key Management
Backup buckets	SSE-KMS (AES-256)	Customer-managed CMK
Archive buckets	SSE-KMS (AES-256)	Customer-managed CMK
Log buckets	SSE-S3	AWS-managed

Bucket Policy Enforcement:

```
json
```

```
{
```

```
"Version": "2012-10-17",
```

```
"Statement": [{
```

```
"Sid": "DenyUnencryptedUploads",
```

```
"Effect": "Deny",
```

```

"Principal": "",
"Action": "s3:PutObject",
"Resource": "arn:aws:s3:::company-a-/",
"Condition": {
  "StringNotEquals": {
    "s3:x-amz-server-side-encryption": "aws:kms"
  }
}
}
}}
}

```

3.3 Endpoint Encryption

3.3.1 Windows Endpoints

Component	Tool	Key Recovery	Status
System Drive	BitLocker (AES-256)	Active Directory	Mandatory
Removable Media	BitLocker To Go	AD or Passphrase	Required for CONFIDENTIAL+

Group Policy Requirements:

- Encryption method: XTS-AES 256-bit
- Pre-boot authentication: TPM 2.0 + PIN
- Recovery key backup: Active Directory

3.3.2 macOS Endpoints

Component	Tool	Key Recovery	Status
System Volume	FileVault 2 (XTS-AES-128)	Jamf Pro escrow	Mandatory
Time Machine	Encrypted backups	User password	Required

3.3.3 Mobile Devices

Platform	Encryption	Management
iOS	Hardware AES-256 (default)	Microsoft Intune
Android	File-based encryption	Microsoft Intune

MDM Policy Requirements:

- Encryption enforced before enrollment completion
- Minimum 6-digit PIN or biometric

- Remote wipe capability enabled

3.4 Virtual Machine Encryption

3.4.1 VMware vSphere

Component	Method	Key Management
VM Encryption	vSphere Native (AES-256)	External KMS
vMotion Encryption	Encrypted vMotion	Automatic
vSAN Encryption	At-rest and in-transit	External KMS

Encrypted VM Categories:

- All VMs containing CONFIDENTIAL or SECRET data
- Database servers
- Domain controllers
- Security infrastructure

4. DATA IN TRANSIT ENCRYPTION

4.1 Web Traffic (HTTPS)

4.1.1 TLS Version Requirements

Use Case	Minimum Version	Preferred Version
Public websites	TLS 1.2	TLS 1.3
Internal applications	TLS 1.2	TLS 1.3
API endpoints	TLS 1.2	TLS 1.3
Administrative interfaces	TLS 1.3	TLS 1.3

4.1.2 Approved Cipher Suites (TLS 1.3)

Cipher Suite	Status
TLS_AES_256_GCM_SHA384	APPROVED (preferred)
TLS_AES_128_GCM_SHA256	APPROVED
TLS_CHACHA20_POLY1305_SHA256	APPROVED

4.1.3 Approved Cipher Suites (TLS 1.2)

Cipher Suite	Status
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384	APPROVED
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	APPROVED
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384	APPROVED
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384	APPROVED (DHE 2048+)

4.1.4 Certificate Requirements

Attribute	Requirement
Key Algorithm	RSA 3072+ or ECDSA P-384
Signature Algorithm	SHA-256 or higher
Validity Period	Maximum 1 year (public), 2 years (internal)
Certificate Authority	DigiCert (public), Internal PKI (internal)
OCSP Stapling	Required for public certificates
Certificate Transparency	Required for public certificates

Prohibited:

- Self-signed certificates in production
- Wildcard certificates for internet-facing services
- SHA-1 signed certificates

4.2 File Transfer Protocols

4.2.1 Approved Protocols

Protocol	Port	Use Case	Status
SFTP	22	Secure file transfer	APPROVED (preferred)
SCP	22	Secure copy	APPROVED
FTPS (Explicit)	21/990	Legacy compatibility	APPROVED
HTTPS	443	Web-based transfer	APPROVED
AS2	443	B2B EDI	APPROVED

4.2.2 Prohibited Protocols

Protocol	Risk	Alternative
FTP	Cleartext credentials	SFTP
Telnet	Cleartext session	SSH
HTTP	Cleartext data	HTTPS
SMBv1	EternalBlue vulnerability	SMBv3

4.3 Email Encryption

4.3.1 Transport Layer

Path	Encryption	Status
Internal (Exchange to Exchange)	TLS 1.2+ enforced	Enabled
External (outbound)	Opportunistic TLS	Enabled
External (inbound)	Opportunistic TLS	Enabled
Partner connectors	Forced TLS	Configured per partner

4.3.2 Message-Level Encryption

Classification	Encryption Method
INTERNAL	Transport only
CONFIDENTIAL	Microsoft Purview Message Encryption
SECRET	S/MIME with hardware certificates

4.3.3 Microsoft Purview Configuration

Setting	Value
Encryption template	"Confidential - Company A"
Recipient authentication	Microsoft account or OTP
Forwarding	Disabled for SECRET
Print/Copy	Disabled for SECRET

4.4 Database Connections

4.4.1 Oracle Database

Connection Type	Encryption	Authentication
SQLNet	Native Network Encryption (AES256)	Kerberos / LDAP
JDBC Thin	SSL/TLS	Certificate-based
Oracle Data Guard	Redo transport encryption	Password file

4.4.2 SQL Server

Connection Type	Encryption	Authentication
TDS	Force Encryption = Yes	Windows Integrated
ODBC/JDBC	Encrypt = True	Certificate validation
AlwaysOn AG	Certificate-based	Windows Auth

4.5 API Security

4.5.1 REST API Requirements

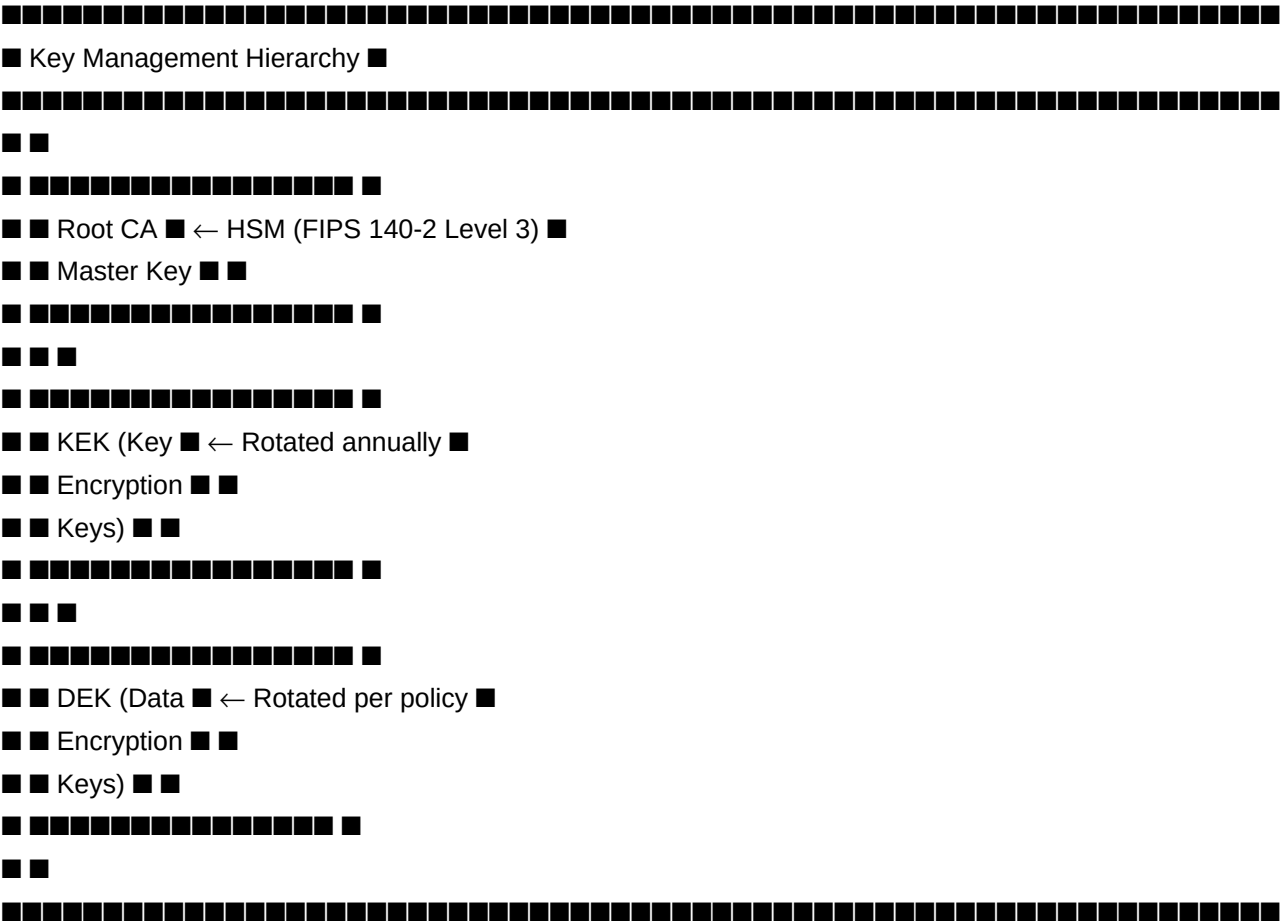
Requirement	Standard
Transport	TLS 1.2+ only
Authentication	OAuth 2.0 + JWT
Token signing	RS256 or ES256
Token encryption	JWE (optional for sensitive claims)

4.5.2 HL7 FHIR (Healthcare APIs)

Requirement	Standard
Transport	TLS 1.2+ with mutual TLS
Authentication	SMART on FHIR (OAuth 2.0)
Authorization	Scope-based access

5. KEY MANAGEMENT SYSTEM (KMS)

5.1 Key Management Architecture



5.2 Hardware Security Module (HSM)

5.2.1 HSM Specifications

Attribute	Specification
Vendor	Thales Luna Network HSM 7
Model	Luna Network HSM A790
FIPS Level	140-2 Level 3
Quantity	2 (HA pair)
Location	Primary DC (Riyadh) + DR (Jeddah)

5.2.2 HSM-Protected Keys

Key Type	Purpose	HSM Partition
Root CA Private Key	PKI root	PKI_ROOT
Issuing CA Keys	Certificate signing	PKI_ISSUING
TDE Master Keys	Database encryption	TDE_KEYS
Code Signing Key	Application signing	CODESIGN

5.3 Key Lifecycle Management

5.3.1 Key Generation

Requirement	Standard
Random Number Generator	NIST SP 800-90A DRBG
Generation Location	HSM only for master keys
Witness Requirement	Dual control for root keys

5.3.2 Key Rotation Schedule

Key Type	Rotation Period	Automated
TDE DEK	1 year	Yes (Oracle/SQL Server)
TDE KEK	2 years	Manual with HSM
SSL/TLS Certificates	1 year	Yes (ACME)
API Signing Keys	6 months	Semi-automated
Root CA Key	20 years	Manual ceremony
Issuing CA Key	5 years	Manual ceremony

5.3.3 Key Destruction

Method	Use Case	Verification
Crypto-shredding	Encrypted data disposal	Audit log
HSM Key Deletion	Decommissioned systems	Dual approval
Secure Overwrite	Backup key copies	DoD 5220.22-M

5.4 Split Knowledge and Dual Control

5.4.1 Principles

Principle	Definition
Split Knowledge	No single person knows the complete key/password
Dual Control	Two or more persons required for sensitive operati
M of N	M persons required out of N total custodians

5.4.2 Implementation

Operation	Control	Personnel
HSM Initialization	3 of 5	Security Officers
Root CA Activation	2 of 3	Key Custodians
KEK Rotation	2 of 3	Security + DBA
Emergency Access	2 of 3	Security Officers

5.5 Key Escrow and Recovery

5.5.1 Escrow Locations

Key Type	Escrow Location	Access Control
BitLocker Recovery	Active Directory	Domain Admins
FileVault Recovery	Jamf Pro	IT Security
HSM Backup	Physical safe (bank)	Key Custodians (3 of 5)

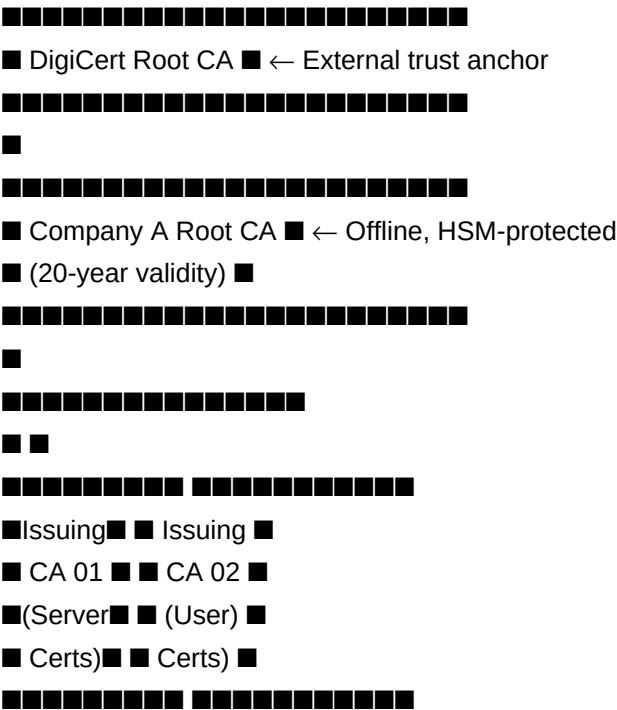
5.5.2 Recovery Procedures

Scenario	Procedure	Authorization
Lost laptop	BitLocker recovery via AD	IT Helpdesk + Manager
HSM failure	Restore from backup	Security Officer + CDO
Compromised key	Emergency rotation	Incident Response Team

6. CERTIFICATE MANAGEMENT

6.1 Public Key Infrastructure (PKI)

6.1.1 CA Hierarchy



6.1.2 Certificate Templates

Template	Key Usage	Validity	Requestor
Web Server	Server Auth	1 year	Auto-enroll
Client Auth	Client Auth	1 year	Auto-enroll
Code Signing	Code Sign	2 years	Manual approval
Email (S/MIME)	Email Protection	1 year	Auto-enroll

6.2 Certificate Lifecycle

Phase	Action	Automation
Request	CSR submission	PKI portal
Approval	Policy validation	Auto/Manual
Issuance	Certificate generation	Automatic
Distribution	Push to systems	Auto-enroll
Monitoring	Expiration alerts	60/30/14/7 days

Renewal	New certificate	Automatic
Revocation	CRL/OCSP update	Manual + automatic

6.3 Certificate Monitoring

System	Certificates	Alert Threshold
Load balancers	12	30 days
Web servers	45	30 days
API gateways	8	30 days
Database SSL	15	30 days

7. COMPLIANCE AND MONITORING

7.1 Encryption Compliance Checks

Check	Frequency	Tool	Responsibility
TDE status verification	Weekly	SQL scripts	DBA Team
Certificate expiration	Daily	Certificate inventory	PKI Admin
Endpoint encryption	Daily	Intune compliance	IT Security
TLS configuration	Monthly	Qualys SSL Labs	Security Team
Key rotation status	Monthly	HSM reports	Key Custodians

7.2 Vulnerability Scanning

Scan Type	Target	Frequency	Tool
SSL/TLS Configuration	All HTTPS endpoints	Weekly	Qualys
Cipher suite analysis	External services	Monthly	SSL Labs
Certificate chain	Public websites	Weekly	Certificate Transparency
Protocol version	All services	Monthly	Nessus

7.3 Exception Management

Exception Type	Approval	Maximum Duration	Review
Legacy cipher (3DES)	Security Board	6 months	Quarterly
Self-signed cert (dev)	Security Team	3 months	Monthly
Extended key validity	Security Board	1 year	Semi-annual

APPENDIX A: CIPHER SUITE CONFIGURATION

A.1 Apache/nginx TLS Configuration

```
apache
SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1
SSLCipherSuite ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384:ECDHE-ECDS
A-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256
SSLHonorCipherOrder on
SSLSessionTickets off
```

A.2 Windows Server (IIS/Schannel)

```
powershell
Disable TLS 1.0 and 1.1

New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server'
-Force
Set-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server'
-Path 'Enabled' -Name 'Enabled' -Value 0
```

APPENDIX B: KEY CEREMONY PROCEDURES

B.1 Root CA Key Ceremony Checklist

Step	Action	Witness 1	Witness 2	Witness 3
1	Verify secure room access	■	■	■
2	Initialize HSM	■	■	■

3	Generate root key pair	■	■	■
4	Create self-signed certificate	■	■	■
5	Export public key	■	■	■
6	Split administrator password	■	■	■
7	Secure backup to safe	■	■	■
8	Document and sign ceremony log	■	■	■

Document End

Security Architecture Board
Company A - Saudi Healthcare Authority
Email: security@companya.gov.sa
Version 1.6 | May 2024